Memoria incremental del proyecto
Sprint 1 – v1.0

Proyecto: Honeynet Adaptativo con Verificación Automática de Superficie de Ataque.

Alumno: Adrián Mirabent Landero.

Centro: IES La Marisma (Huelva).

Sumario

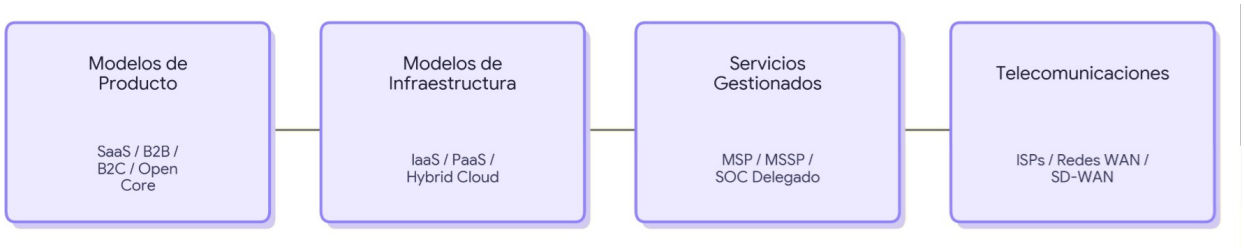
CAPÍTULO 1. CONCEPCIÓN, VIABILIDAD Y BACKLOG.....3
A. CLASIFICACIÓN DEL SECTOR Y ENTORNO DE APLICACIÓN.....3
B. ESTRUCTURA ORGANIZATIVA Y ROLES TÉCNICOS.....5
C. DETECCIÓN DE NECESIDADES Y DOLENCIAS.....6
D. VALORACIÓN DE OPORTUNIDADES Y VIABILIDAD.....8
E. DEFINICIÓN DE LA TIPOLOGÍA DE PROYECTO Y ALCANCE.....11
F. INGENIERÍA DE REQUISITOS Y ELECCIÓN JUSTIFICADA DEL STACK.....13
G. MARCO LEGAL, FISCAL, LABORAL, PRL Y CIBERSEGURIDAD.....16
H. AYUDAS, SUBVENCIONES E INCENTIVOS A LA INNOVACIÓN.....19
I. GUIÓN DE TRABAJO, BACKLOG Y METODOLOGÍA ÁGIL.....21

CAPÍTULO 1. CONCEPCIÓN, VIABILIDAD Y BACKLOG.

A. CLASIFICACIÓN DEL SECTOR Y ENTORNO DE APLICACIÓN.

Dentro del sector de las TIC (Tecnologías de la Información y la Comunicación), se diferencian cuatro modelos de negocio:

- Modelos de Producto: Ofrecen servicios en la nube orientados a la productividad, gestión o seguridad.
- Modelos de Infraestructura: Ofrecen arquitecturas encargadas de proporcionar la potencia de cálculo, almacenamiento, redes y virtualización.
- Servicios Gestionados: Dedicados a monitorizar, auditar y proteger las infraestructuras de terceros.
- Telecomunicaciones: Dedicados al transporte de datos y conectividad segura.



Nuestro proyecto se encuadra en el modelo de negocio de Servicios Gestionados, dentro de los modelos de prestación de servicios MSSP y SOC Delegado.

Un MSSP, Managed Security Service Provider (Proveedor de Servicios de Seguridad gestionados) es una empresa externa especializada que se encarga de instalar, configurar, actualizar y mantener las herramientas de seguridad de una organización. Su enfoque es de gestión y administración general.

Un SOC delegado, Security Operations Center (Centro de Operaciones de Seguridad) analiza en tiempo real las alertas y los datos que generan las herramientas de seguridad instaladas en la organización, buscando patrones sospechosos para frenar un ciberataque antes de que cause daño. Su enfoque es la vigilancia analítica y la respuesta rápida. Normalmente formado por software especializado y analistas de seguridad. Actualmente, un SOC delegado suele ser un servicio que ofrece un MSSP.

Nuestro proyecto se plantea como un modelo de negocio de SOC Delegado avanzado, que reduce al mínimo la intervención humana. Se desplegaría nuestra arquitectura en una organización determinada y nuestro sistema inteligente será capaz de analizar los ataques reales recibidos en las trampas y evaluará de forma automatizada si ponen en riesgo los servidores reales de dicha organización. Si la respuesta es Sí, se da una alerta real y crítica.

A nivel comercial proponemos para nuestro proyecto el modelo SECaaS (Security as a Service), ofreciendo a los clientes un Contrato de Mantenimiento con SLA, por lo cual cobramos una cuota periódica de la organización que nos ha contratado.

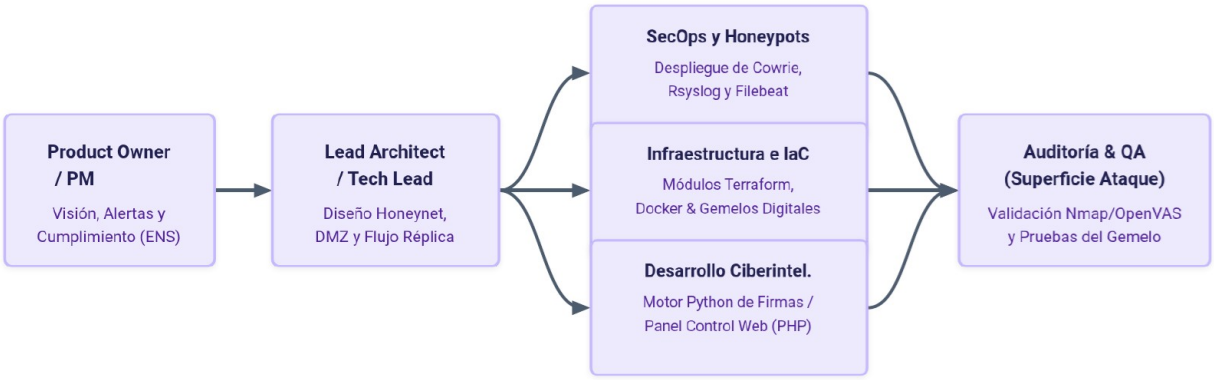
El SLA, Service Level Agreement (Acuerdo de Nivel de Servicio) es la cláusula más importante dentro del contrato. En esta cláusula se recogen métricas objetivas y medibles que nuestra empresa garantiza que va a cumplir. Si no cumplimos, suele tener sanciones o penalizaciones contractuales. Algunas métricas típicas son Tiempo de resolución (el tiempo máximo garantizado para arreglar un fallo o mitigar una amenaza) y la Disponibilidad (el porcentaje de tiempo que el servicio estará 100% operativo).

Existen muchas empresas que se dedican a ofrecer el servicio de SOC delegado:

- Las más importantes a nivel mundial son Artic Wolf y Huntress.
- Algunas empresas españolas son Entelgy Innotec Security, Softeng, Grupo Linka, Tarlogic Security y Abast.

B. ESTRUCTURA ORGANIZATIVA Y ROLES TÉCNICOS.

Para nuestro proyecto, proponemos el siguiente organigrama técnico:



Definimos los roles o departamentos:

Product Owner / Product Manager: Define el producto, los criterios con los que se evaluará un ataque a nuestra Honeynet y se asegura el cumplimiento de los marcos de seguridad.

Lead Architect / Tech Lead: Diseña la arquitectura defensiva, el aislamiento en la DMZ y el protocolo de réplica automatizada de comandos contra el gemelo digital.

SecOps & Honeypots: Despliega y mantiene el honeypot Cowrie, gestiona la captura de eventos en tiempo real con Filebeat/Rsyslog y gestiona la seguridad de los contenedores expuestos.

Infraestructura e IaC (DevOps): Automatiza mediante Terraform la infraestructura de red virtualizada y orquesta los entornos en Docker para clonar los servicios reales de la organización.

Desarrollo de Ciberinteligencia: Programa los scripts en Python para la extracción de patrones de ataque y desarrolla la interfaz gráfica en PHP para la visualización de alertas.

Auditoría y QA (Quality Assurance): Ejecuta la automatización ofensiva con Nmap y OpenVAS sobre el gemelo digital para comprobar la existencia de vulnerabilidades reales tras un ataque.

El alumno operando como un Equipo Unipersonal de Alto rendimiento, asume de forma integral la responsabilidad de todos los roles descritos.

C. DETECCIÓN DE NECESIDADES Y DOLENCIAS.

Contexto de la problemática detectada.

Las empresas que delegan su seguridad en proveedores de servicios gestionados se enfrentan a amenazas constantes y cada vez más sofisticadas.

Los sistemas de monitorización defensiva tradicionales te avisan de miles de intentos de ataque, pero no comprueban de forma automática si la infraestructura de la empresa es realmente vulnerable a esos ataques. Esto hace que los administradores del servicio pierdan mucho tiempo analizando falsas alarmas y en la mayoría de las veces este análisis no es en tiempo real, por lo que el daño podría ya estar hecho cuando vayan a realizar ese análisis.

Identificación de las dolencias.

- **Aumento masivo de falsos positivos y fatiga de alertas:** Los sistemas de seguridad convencionales generan una gran volumen de alertas genéricas y los analistas de seguridad (SecOps) invierten muchas horas de trabajo discriminando eventos inofensivos, lo que aumenta el tiempo de respuesta ante ataques reales.

- **Falta de evaluación del comportamiento del atacante:** Las herramientas de trampas convencionales (Honeypots) permiten observar que un atacante interactúa con un servicio simulado, pero no evalúa de forma automática si ese tipo de ataque pone en riesgo la infraestructura real de la organización.

- **Desfase temporal en la auditoría de la superficie de ataque:** Las auditorías de vulnerabilidades convencionales suelen realizarse de forma periódica. Por lo que durante el periodo de tiempo entre el ataque y la auditoría, queda abierta una ventana de vulnerabilidad.

- **Falta de automatización preventiva:** No existen herramientas integradas que automaticen un escaneo dirigido sobre un gemelo digital para comprobar si la infraestructura es vulnerable al ataque.

Propuesta de valor.

Se detecta la necesidad de desarrollar un proyecto que cumpla con los siguientes requisitos:

- **Aislamiento de los contenedores Docker:** Los honeypots se confinan en una DMZ, de manera que el atacante a un honeypot quede confinado en el DMZ sin capacidad de acceder a la infraestructura real.

- **Despliegue ágil y automatizado mediante infraestructura como Código (IaC):** La integración de Terraform en la arquitectura de la Honeynet te permite el despliegue con un solo comando. Una vez definida la infraestructura base, toda la topología de la Honeynet puede ser levantada o destruida mediante un único comando, optimizando drásticamente el tiempo de puesta en marcha. Además, permite crear tantos señuelos (honeypots) como se requiera de forma instantánea. Otra ventaja importante es que cualquier honeypot que resulte dañado o corrompido durante un ataque podrá ser destruido y reemplazado por una réplica limpia e idéntica en cuestión de segundos.

- **Motor de inteligencia (Python):** Se requiere un sistema centralizado que recoja los logs de los honeypots y procese mediante scripts en Python los patrones de los atacantes en tiempo real.

- **Verificación automática de superficie de ataque (gemelo digital):** Se automatizará la ejecución de herramientas ofensivas (Nmap/OpenVAS) contra un gemelo digital de la empresa tras la detección de un ataque, validando si el riesgo es real, generando informes.

- **Interfaz de control (PHP):** Se dispondrá de un panel web intuitivo desarrollado en PHP donde se podrán visualizar las alertas priorizadas, el nivel de seguridad y el estado de la superficie de ataque.

D. VALORACIÓN DE OPORTUNIDADES Y VIABILIDAD.

ANÁLISIS ESTRATÉGICO DAFO.

Análisis externo.

Oportunidades:

- Alta demanda de soluciones automatizadas debido a dos factores: el incremento de los ciberataques y el alto coste que le implica a una empresa de disponer de un equipo SOC (Security Operations Center) propio. Por estos motivos, las empresas recurren cada vez más a las MSSP (proveedores de servicios gestionados de seguridad).

- Existe presión regulatoria de los gobiernos, que exige a las empresas la auditoría continua de su superficie de ataque y la gestión temprana de vulnerabilidades.

- Acceso a programas de financiación y ayudas públicas para la transformación digital y el refuerzo de la ciberseguridad corporativa.

Amenazas:

- Incremento en la sofisticación de las ciberamenazas y desarrollo de técnicas de evasión por parte de los atacantes para detectar entornos simulados (honeypots).

- Posibles cambios en el licenciamiento de las tecnologías usadas en el proyecto que provoquen un coste imprevisto.

Análisis interno.

Fortalezas:

- Uso de tecnologías Open Source con un alto grado de madurez técnica (Terraform, Docker, Python, Nmap, OpenVAS, PHP, Cowrie).

- Al tratarse de software de código abierto, no se requiere el pago de licencias de software propietario ni de herramientas comerciales caras.

Debilidades:

- Una única persona abarca todos los roles del equipo. Esto limita el alcance del proyecto.

- Tiempo limitado para el desarrollo del proyecto, lo cual también limita.

EVALUACIÓN DE LA VIABILIDAD.

Viabilidad técnica.

- La arquitectura del proyecto se basa en tecnologías Open Source y estándares de la industria con un alto grado de madurez técnica (Terraform, Docker, Python, Nmap, OpenVAS, PHP, Cowrie).

- Aislamiento por diseño de los honeypots, evitando fugas hacia el sistema de producción.

Viabilidad económica.

- Baja inversión inicial (CAPEX): Al utilizar íntegramente un software de código abierto, no se requiere el pago de licencias de software propietario ni de herramientas comerciales caras.

- Costes de operación reducidos (OPEX): La infraestructura puede ser desplegada de forma automática con pocos recursos gracias a la eficiencia de los contenedores Docker. Además, la recepción e interpretación de datos enviados por los honeypots y la verificación de la superficie de ataque también es automática.

- Retorno de inversión (ROI) rápido: La automatización de muchos de los procesos se traduce en una reducción de los costes operativos y en la capacidad de ofrecer contratos muy competitivos. Por lo que nos facilita la contratación de clientes y con el dinero recaudado podemos recuperar en poco tiempo la inversión inicial realizada en el proyecto.

Viabilidad operativa y organizativa: Sostenibilidad y Mantenimiento.

- A través del motor de Pyton y el panel en PHP se centraliza la operativa del proyecto.

- Toda la infraestructura está definida mediante código (IaC), lo que permite un fácil mantenimiento y auditorías rápidas.

- El proyecto está diseñado para ser operado por perfiles técnicos estándar definidos en el punto B.

- La capacidad de destruir y volver a desplegar la Honeynet en segundos mediante Terraform minimiza la carga de mantenimiento del equipo de operaciones en caso de un ataque grave.

CONCLUSIONES.

El desarrollo de nuestro proyecto debe ejecutarse porque existe una clara ventaja competitiva con respecto a las empresas existentes del sector, en los siguientes aspectos:

- **Diferenciación frente a los Honeypots tradicionales:** Los honeypots convencionales solo recopilan logs. La gran oportunidad de esta plataforma es la verificación automática del riesgo real: al conectar la trampa con el escaneo sobre el gemelo digital, entrega en tiempo real un informe preciso del impacto que puede producir en su organización un determinado ataque.

- **Riesgo financiero mínimo:** Al apoyarse en software de código abierto y en Infraestructura como Código, los costes de desarrollo y despliegue son bajos.

- **Optimización de costes:** La automatización reduce radicalmente el número de horas dedicadas a la instalación y mantenimiento del sistema, y también se reducen las horas que deben dedicar a la valoración manual de alertas. Esto nos permite gestionar un mayor número de clientes sin aumentar nuestros costes en personal.

E. DEFINICIÓN DE LA TIPOLOGÍA DE PROYECTO Y ALCANCE.

Tipología del proyecto.

El proyecto se clasifica fundamentalmente dentro de la categoría de **Plataforma de Ciberseguridad / SOC**. También hay que tener en cuenta su relación con otras dos categorías:

- **Infraestructura Cloud / Híbrida basada en IaC y Contenedores**: Por el aprovisionamiento con Terraform y Docker.
- **Plataforma Web SaaS / Dashboard de Gestión**: Por el diseño del panel de administración desarrollado en PHP para la centralización de alertas.

Delimitación de fronteras del proyecto.

Para evitar la dispersión de esfuerzos durante las fases de desarrollo del proyecto, tenemos que dejar definida la línea base del alcance (**Scope Baseline**).

Para conseguir este objetivo, tenemos que delimitar las fronteras, es decir, lo que está en el alcance del proyecto (**In-Scope**) y lo que está fuera del alcance del proyecto (**Out-of-Scope**).

En Alcance (In-Scope).

- **Aprovisionamiento automatizado (Terraform):** Despliegue y destrucción automatizada de la red virtual privada y los contenedores de señuelos mediante archivos de configuración declarativos (main.tf).
- **Señuelo de Servicios (Cowrie):** Despliegue, configuración y recolección de logs de intentos de acceso por fuerza bruta e interacción de atacantes.
- **Aislamiento (Docker):** Configuración de contenedores mediante usuarios sin privilegios, sistemas de archivos en modo lectura y eliminación de capacidades para evitar saltos a producción.
- **Motor de automatización (Python):** Script encargado del análisis de eventos de *Cowrie* en tiempo real, extracción de los IPs de los atacantes y puesta en marcha de forma automática del proceso de escaneo y verificación de seguridad.
- **Verificación automática sobre el gemelo digital:** Lanzamiento automático de escaneos dirigidos con Nmap (puertos) y OpenVAS (vulnerabilidades) contra la réplica del cliente para confirmar el riesgo real sin falsos positivos.

- **Panel de Control Web (PHP):** Panel funcional para la visualización centralizada de incidentes, nivel de severidad de vulnerabilidades y generación de informes de estado.

Fuera de Alcance (*Out-of-Scope*).

- **Sistemas basados en Inteligencia Artificial:** Modelos para la detección predictiva de patrones de ataque no conocidos o comportamiento anómalo.

- **Acciones inmediatas automatizadas en producción tras la detección de un riesgo real en el escaneo del gemelo digital :** Reconfiguración autónoma de los firewalls o servidores de producción del cliente sin supervisión previa.

Justificación del alcance.

Con lo que hemos definido dentro del alcance del proyecto, nos permite obtener un Producto Mínimo Viable (MVP) sólido y funcional.

Lo que queda fuera del alcance del proyecto evita riesgos en los plazos de entrega y garantiza su cumplimiento.

F. INGENIERÍA DE REQUISITOS Y ELECCIÓN JUSTIFICADA DEL STACK.

INGENIERÍA DE REQUISITOS

Vamos a determinar los requisitos del proyecto según la norma internacional ISO/IEC 25010 de calidad de producto tecnológico. En esta norma se diferencia entre:

- **Requisitos funcionales (RF):** Capacidades o acciones concretas que debe ejecutar el proyecto.
- **Requisitos no funcionales (RNF):** Atributos de calidad y rendimiento de nuestro proyecto.

REQUISITOS FUNCIONALES.

RF-01
Aprovisionamiento por IaC: El sistema debe permitir el despliegue y destrucción automatizada de la topología de red virtual y los contenedores señuelos mediante Terraform.

RF-02
Captura de tráfico y amenazas: El señuelo (Cowrie) debe registrar los intentos de acceso, ataques por fuerza bruta y comandos ejecutados por los atacantes.

RF-03
Preparación de los datos y análisis en tiempo real: el motor de Python debe procesar de manera continua los registros de los honeypots para extraer las IPs de origen de los atacantes y las pruebas de su ataque.

RF-04
Comienzo del escaneo defensivo: Ante la detección de un ataque relevante, el sistema debe ordenar de forma automática un escaneo de verificación sobre el gemelo digital.

RF-05
Auditoría de superficie: Ejecución automática de Nmap y OpenVAS para comprobar el riesgo real.

RF-06
Visaulización: El panel web en PHP debe mostrar de forma centralizada las alertas, la importancia del riesgo y el estado de nuestra infraestructura.

REQUISITOS NO FUNCIONALES.

RNF-01
Rendimiento y ligereza: Uso eficiente de recursos mediante contenedores Docker, permitiendo que el despliegue consuma poca memoria RAM, posibilitando pruebas fluidas.

RNF-02
Seguridad por diseño: Aplicación estricta de directivas en los contenedores Docler para evitar escapes hacia la red de producción.

RNF-03
Capacidad de recuperación ante desastres: Tiempo de restablecimiento muy reducido tras ejecutar la destrucción y redespliegue con Terraform.

RNF-04
Fácil mantenimiento y escalabilidad: Uso de la Infraestructura como Código (IaC), lo que facilita la adición de nuevos señuelos sin alterar la arquitectura central.

SELECCIÓN JUSTIFICADA DEL STACK TECNOLÓGICO

A continuación, vamos a justificar la elección de cada componente tecnológico.

SISTEMA OPERATIVO BASE
Seleccionamos **Ubuntu** debido a su alta estabilidad, soporte a largo plazo y compatibilidad nativa con motores de contenedores.

INFRAESTRUCTURA COMO CÓDIGO
Seleccionamos **Terraform (HashiCorp)** por su buena consideración y soporte oficial para Docker.

CONTENERIZACIÓN
Seleccionamos **Docker** por su ligereza, aislamiento por contenedores y bajo consumo de recursos frente a la virtualización tradicional.

HONEYPOT / SEÑUELO
Seleccionamos **Cowrie** por ser un honeypot interactivo ideal para capturar ataques por fuerza bruta y comandos maliciosos, todo ello sin comprometer a los sistemas reales.

MOTOR DE AUTOMATIZACIÓN
Seleccionamos **PYTHON** por su gran versatilidad en el manejo de ficheros, expresiones regulares muy útiles para el análisis de los logs y facilidad de integración con APIs externas de seguridad.

ESCANEO Y VERIFICACIÓN
Seleccionamos **Nmap** y **OpenVAS** para conseguir la eficaz auditoría de puertos y escaneo profundo de vulnerabilidades sobre el gemelo digital.

PANEL DE CONTROL WEB
Seleccionamos **PHP** por su rapidez de desarrollo y facilidad de despliegue.

G. MARCO LEGAL, FISCAL, LABORAL, PRL Y CIBERSEGURIDAD.

CIBERSEGURIDAD, PRIVACIDAD Y REGULACIÓN.

RGPD / LOPD-GDD

RGPD: Reglamento General de Protección de Datos, normativa de la Unión Europea.

LOG-GDD: Ley Orgánica de Protección de Datos Personales y Garantía de los Derechos Digitales, normativa española que adapta el ordenamiento jurídico español al RGPD.

Nuestro proyecto captura las evidencias digitales de que nuestros honeypots han sido atacados. Se les llama indicadores de compromiso (IoCs). Dado que la dirección IP es considerado un dato de carácter personal si permite la identificación indirecta de una persona, nuestro proyecto se acoge al principio de Privacidad desde el diseño (Privacy by Design), que implica establecer la privacidad y la protección de la información desde la fase inicial de diseño.

Los datos recolectados por el honeypot (Cowrie) y el panel web tienen un fin exclusivamente defensivo, analítico y de seguridad de la red. En ningún caso se comercializarán ni se emplearán para la elaboración de perfiles con fines comerciales.

DIRECTIVA NIS2 Y ENS.

NIS2: Network and Information Security 2, normativa sobre Seguridad de las Redes y de la Información, actualización de NIS, normativa de la Unión Europea.

ENS: Esquema General de Seguridad, normativa española que adapta el ordenamiento jurídico español al NIS2.

Nuestro proyecto posee ciberresilencia, que es la capacidad que tiene un sistema para resistir ataques, responder rápidamente ante incidentes y seguir funcionando sin ser destruido. Cumple los estándares de la NIS2 y el ENS, porque captura la amenaza en un señuelo, analiza las huellas del atacante y verifica de forma inmediata si el sistema real está en peligro.

EU AI Act:

EU AI Act: Ley de Inteligencia Artificial de la Unión Europea.

Esta normativa regula exclusivamente sistemas que utilicen algoritmos de Inteligencia Artificial. Nuestro proyecto se basa en automatización mediante scripts, por lo que no aplica a nuestro proyecto.

LICENCIAMIENTO DE SOFTWARE Y HARDWARE.

Todo el stack tecnológico del proyecto se sustenta bajo licencias de código abierto (Open Source).

Ubuntu: Distribuido bajo licencias libres y de código abierto (principalmente GNU GPL y otras licencias de software libre de Linux). Permite su uso, estudio y redistribución.

Terraform (HashiCorp): Permite legalmente crear, ejecutar y automatizar infraestructuras informáticas de forma libre y sin restricciones técnicas ni comerciales para este tipo de tareas.

Docker Engine: Utiliza licencias de código abierto para su motor base (Moby Project /Apache License 2.0), permitiendo la contenerización y aislamiento de servicios de forma legal y gratuita.

Cowrie: Licenciado bajo licencia MIT, una licencia altamente permisiva que permite su uso comercial y académico libre con la única condición de conservar los avisos de autoría original.

Python y librerías de automatización: Lenguaje interpretado de código abierto bajo Python Software Foundation License, junto con las librerías estándar libres para el procesamiento de ficheros y tratamiento de logs.

Nmap y OpenVAS: Herramientas de ciberseguridad ofensiva y auditoría distribuidas bajo licencias públicas generales (GNU GPLv2 / GPL v3), permitiendo su libre ejecución en entornos de pruebas y auditorías autorizadas.

PHP: Lenguaje de código abierto bajo PHP Licence para la estructuración y creación del panel web de control.

FISCALIDAD, MARCO LABORAL Y PRL.

MARCO FISCAL Y FORMA JURÍDICA.

El Trabajo Fin de Ciclo (TFC) podría pasar de prototipo académico a un proyecto empresarial desarrollado por un profesional autónomo o pequeña empresa tecnológica (startup).

Bajo esta forma, nos podríamos acoger a las ventajas de fomento del emprendimiento digital y la innovación tecnológica vigentes en la legislación española. La Ley de Startups (Ley 28/2022 de Fomento del Ecosistema de Empresas Emergentes) es un ejemplo. Algunas de las ventajas son:

- Reducción del impuesto de sociedades al del 25% al 15%.
- Aplazamientos fiscales sin intereses.
- Deducción del 50% del IRPF para posibles inversores.

MARCO LABORAL.

El desarrollo del proyecto se lleva a cabo bajo pautas de organización flexibles, cumplimiento con la legislación vigente sobre el trabajo a distancia y el registro de jornada cuando aplique, garantizando la desconexión digital y los derechos laborales básicos del desarrollador.

PREVENCIÓN DE RIESGOS LABORALES.

Durante el desarrollo del proyecto se cumple rigurosamente las normas de Prevención de Riesgos Laborales (PRL) relativas al uso de Pantallas de Visualización de Datos (PVD), con los siguientes puntos:

- Ergonomía visual y postural: Uso de mobiliario adecuado, manteniendo una distancia correcta con respecto al monitor y descansos periódicos para evitar la fatiga visual y muscular.

- Seguridad eléctrica y del entorno de trabajo: Uso de conexiones eléctricas homologadas y mantenimiento de un espacio de trabajo ordenado y libre de riesgos físicos.

H. AYUDAS, SUBVENCIONES E INCENTIVOS A LA INNOVACIÓN.

Vamos a analizar las posibles vías de financiación pública e incentivos a la innovación aplicables a nuestro proyecto si pasara a ser una empresa de base tecnológica (startup).
Además de su descripción, vamos a hacer un análisis de los requisitos de acceso, cuantías asignables e impacto en la viabilidad del proyecto.

Kit Digital (Fondos NextGenerationEU - Plan de recuperación, Transformación y Resilencia):

Descripción: Es un programa del Gobierno de España diseñado facilitar que las PYMEs se incorporen de forma práctica a las nuevas tecnologías, concediendo subvenciones. Si una pequeña empresa quiere proteger su red e instalar nuestro sistema de Honeynet Adaptativo, no tiene que pagarlo de su bolsillo. Puede solicitar el Kit Digital y usar esa subvención para contratar a nuestra empresa.

Requisitos de acceso:

- Ser PYME, microempresa o autónomo.
- Estar al corriente de obligaciones tributarias y Seguridad Social.
- No haber superado el límite de mínimis (la empresa no puede recibir más de 300000 euros de ayudas de este tipo en un periodo de 3 años).

Cuantías asignables: Bonos de 2000 a 29000 euros.

Impacto en la viabilidad del proyecto: Facilita conseguir clientes, ya que ellos pueden solicitar el Kit Digital y nos pagan con ese dinero que les conceden.

Préstamos Participativos ENISA (Jóvenes emprendedores / Empresas emergentes):

Descripción: ENISA (Empresa Nacional de Innovación) está orientada a proyectos empresariales innovadores promovidos por PYMEs y startups. Puede conceder un préstamo a nuestra empresa para poner en marcha nuestra infraestructura, sin la exigencia de avales personales ni garantías reales y con plazos de amortización largos, con el único requisito de que el proyecto lo consideren viable e innovador.

Requisitos de acceso:

- PYME de reciente creación.
- Producto que ofrece debe ser innovador.
- Préstamo sobre el 50% del dinero necesario para tu proyecto, el resto lo ponen los fundadores de la empresa.

Cuantías asignables: Desde 25000 hasta 75000 euros.

Impacto en la viabilidad del proyecto: Aporta la liquidez necesaria para financiar la infraestructura, licencias adicionales y horas de desarrollo.

Programa CDTI Neotec:

Descripción: CDTI es el Centro de Desarrollo Tecnológico y la Innovación. Neotec es un programa específico que concede subvenciones para la creación de nuevas Empresas de Base Tecnológica (EBT).

Requisitos de acceso:

- Empresa de base tecnológica con menos de 3 años desde su creación.
- Gasto mínimo de I+D (Investigación y Desarrollo) del 15%.
- Capital social mínimo exigido en cada convocatoria.

Cuantías asignables: Entre el 70 y 80% del presupuesto del proyecto (subvención de 175000 a 325000 euros).

Impacto en la viabilidad del proyecto: Permite la contratación de un equipo de desarrollo dedicado a tiempo completo para la expansión de la empresa.

Incentivos y Deducciones Fiscales por I+D+I (Investigación, Desarrollo e Innovación Tecnológica):

Descripción: El Estado español premia fiscalmente (rebaja en el impuesto sobre Sociedades) a las empresas que invierten tiempo y recursos en crear software propio e innovador.

Requisitos de acceso:

- Justificación documental del desarrollo propio del software novedoso.

Cuantías asignables: Deducción directa hasta el 12-15% del gasto durante el desarrollo del sofware tecnológico.

Impacto en la viabilidad del proyecto: Rebaja la carga fiscal de la empresa.

I. GUIÓN DE TRABAJO, BACKLOG Y METODOLOGÍA ÁGIL.

METODOLOGÍA DE GESTIÓN DEL TRABAJO

Para asegurar la trazabilidad, calidad y cumplimiento de los plazos de entrega del proyecto, vamos a utilizar la metodología de gestión Kanban, que nos permite visualizar el flujo de tareas, controlar el trabajo en progreso y maximizar la eficiencia en el desarrollo de nuestro proyecto.

DEFINICIÓN DE FILTROS DE CALIDAD

DoR: Definition of Ready (Requisitos para iniciar una tarea):

- **La Historia de Usuario / Tarea Técnica está redactada bajo el formato estándar: Como [Rol] –> Quiero [Acción] –> Para [Beneficio]**
  Es una plantilla de redacción breve que busca dar respuesta a tres preguntas: ¿Quién lo necesita?, ¿Qué hay que hacer? Y ¿Para qué sirve?

- **Cuenta con criterios de aceptación claros bajo el formato BDD: Dado [Contexto] –> Cuando [Acción] –> Entonces [Resultado]**
  En esta plantilla, primero se expone la situación inicial. Luego se describe la acción y por último define el resultado que debe ocurrir para darlo por superado.

- **La tarea ha sido estimada en Story Points (1,2,3,5,8,13).**
  Las tareas se estiman en complejidad relativa, usando de base la Serie de Fibonacci. Esta escala fuerza saltos más grandes a medida que aumenta la dificultad de la tarea.

- **No existen dependencias de software ni bloqueos previos no resueltos.**

DoD: Definition of Done (Requisitos por dar por finalizada una tarea):

- El código (Python, Terraform, Docker, PHP) queda guardado y documentado en el repositorio Git.

- Se han realizado las pruebas unitarias y de integración satisfactoriamente.

- No existen vulnerabilidades ni errores críticos en la ejecución de scripts o despliegue de contenedores.

WORK IN PROGRESS (WIP)

Se define como trabajo en progreso o trabajo en curso. Representa el conjunto de tareas en las que ya se ha empezado a trabajar pero que aún no han sido finalizadas. En nuestro trablero Kanban se aplican en las columnas In Progress o In Review.

Con WIP ponemos un número máximo de tareas permitidas al mismo tiempo en una columna del tablero.

CONFIGURACIÓN DEL TABLERO KANBAN Y LÍMITES DE TRABAJO

El flujo de trabajo se organiza en 5 columnas consecutivas:

- **Product Backlog:** Listado priorizado de todas las Historias de Usuario y Tareas Técnicas pendientes de todo el proyecto.
- **Sprint Backlog:** Tareas asociadas al Sprint activo.
- **In progress:** Tareas en desarrollo activos (WIP Limit = 2 para evitar multitarea)
- **In Review / QA:** Fase de pruebas funcionales, verificación de código y revisión de documentación (WIP Limit = 2 para evitar multitarea).
- **Done:** Tareas finalizadas que cumplen estrictamente la Definición de Done (DoD).

PRODUCT BACKLOG E HISTORIAS DE USUARIO

Se detalla el **Product Backlog** inicial desglosado en Historias de Usuario y Tareas Técnicas, clasificadas con criterios de aceptación BDD y estimadas según la serie de Fibonacci. Las siglas US significa User Story (Historia de Usuario).

US-01

Historia de Usuario: Desplegar la infraestructura base de de la Honeynet mediante Terraform, para garantizar un entorno declarativo (archivo .tf) y reproducible.

Criterio de aceptación: Dado un fichero de configuración .tf, validado, cuando ejecuto terraform apply se levantan los contenedores aislados de la Honeynet y la red virtual sin errores.

Estimación en Story Points: 5.

US-02

Historia de Usuario: Creación de un script en Python que analice automáticamente los registros de ataques en el Honeypot, para extraer las direcciones IP atacantes e IoCs en tiempo real.

Criterio de aceptación: Dado un ataque registrado en los logs del Honeypot, cuando el script detecta un nuevo evento, entonces la IP atacante se almacena y clasifica en la BDD en menos de 5 segundos

Estimación en Story Points: 8.

US-03

Historia de Usuario: Despliegue de un Gemelo Digital del entorno real con Docker, para ejecutar escaneos de verificación de ataque sin exponer la red de producción.

Criterio de aceptación: Dado la recepción de un nuevo IoC, cuando se dispara la alerta, entonces crear los contenedores del Gemelo Digital en una red Docker privada.

Estimación en Story Points: 8.

US-04

Historia de Usuario: Automatización de las ejecuciones de Nmap y OpenVAS sobre el Gemelo Digital, para comprobar si la vulnerabilidad explotada por el atacante existe en mi red.

Criterio de aceptación: Dado la IP del Gemelo Digital activa, cuando Python invoca los escáneres de seguridad, entonces se genera un reporte con los puertos abiertos y vulnerabilidades detectadas.

Estimación en Story Points: 13.

US-05

Historia de Usuario: Creación de un panel web en PHP, para visualizar las métricas de ataques y alertas de vulnerabilidad en tiempo real.

Criterio de aceptación: Dado que el usuario accede al panel web autenticado, cuando consulta la interfaz, entonces PHP visualizará las tablas de IoCs y el estado del Gemelo Digital.

Estimación en Story Points: 5.

US-06

Historia de Usuario: Elaboración de la memoria técnica y preparación del entorno de demostración para defender el TFC ante el tribunal del IES La Marisma.

Criterio de aceptación: Dado el software desplegado y funcional, cuando se ejecutan las pruebas, entonces se completa la documentación técnica.

Estimación en Story Points: 3

CRONOGRAMA GENERAL

El desarrollo del proyecto se estructura a lo largo de cuatro S*prints* de trabajo, precedidos por una fase inicial de preparación y acompañados de hitos de demostración funcional obligatorios que garantizan el avance incremental del sistema:

KICK-OFF OBLIGATORIO (FASE INICIAL).

Reunión inicial de proyecto y entrega del anteproyecto formal en la plataforma Moodle, estableciendo los objetivos generales.
Creación del tablero Kanban, del repositorio y su conexión con nuestro IDE (Visual Studio Code).

SPRINT 1 (RA1 – Entorno, Viabilidad e Infraestructura Base).

Memoria v1.0:
Redacción del capítulo 1.

Demo Funcional 1 (PoC):
Validación práctica de despliegue automatizado de un señuelo con Terraform y Docker.

SPRINT 2 (RA2 – Arquitectura y Diseño).

Memoria v2.0:
Redacción del capítulo 1 y 2.

Demo Funcional 2:
Integración de la red y flujo de trabajo mediante el scrpit en Python que analiza logs en tiempo real, extrae IoCs y levante el gemelo digital para las auditorías.

SPRINT 3 (R3 - Core MVP y Plan de intervención).

Memoria v3.0:
Redacción del capítulo 1, 2 y 3.

Demo Funcional 3:
Ejecución automatizada de auditorías con Nmap y OpenVAS sobre la superficie expuesta del gemelo digital y representación de los resultados en el cuadro de mando creado el PHP.

SPRINT 4 (R4 - Control de Calidad, Despliegue, Cierre y Evaluación Final).

Memoria v4.0:
Redacción del capítulo 1, 2 ,3 y 4.

Demo Funcional 4:
Presentación del sistema maduro, tras superar las pruebas de integración y estrés de red.

TRIBUNAL FINAL DE EVALUACIÓN

Presentación oral del proyecto ante el tribunal académico acompañado de una demostración práctica en vivo (Live Demo) del ataque simulado y la respuesta adaptativa del sistema.